

DATABASE ENCRYPTION AND ITS APPLICATIONS

Learning Objectives

By the end of this lecture, students should be able to:

- Define encryption and decryption.
- Explain the role of encryption keys.
- Identify applications of encryption in databases.
- Differentiate symmetric and asymmetric encryption.
- Enumerate common encryption standards.
- Recognize threats such as dictionary attacks and methods to counter them.
- Describe the different encryption authentication methods

Introduction to Encryption

- **Encryption:** Transforms data into unreadable form using private/secret key.
- **Decryption:** Reverse process to recover original data.
- **Keys:** Encryption and decryption rely on secret or public/private keys.

Historical & Modern Applications

- **Early Use:** Secret military or diplomatic communication.
- **Modern Use:**
 - Protecting data in transit (internet, mobile networks).
 - Authentication systems.
 - Securing databases with sensitive information (credit cards, SSNs, biometrics).
- **Legal Requirement:** Many jurisdictions mandate encryption of sensitive data to prevent identity theft.

Encryption in Databases

- Protects stored data from unauthorized access (e.g., stolen laptops).
- Prevents misuse of personal information (fraud, impersonation).
- Ensures compliance with data protection laws.

Levels of Encryption in Databases

Encryption in databases can be applied at different levels:

1. **Disk-Level Encryption (Full-Disk Encryption)**
 - Encrypts entire storage media.
 - Protects against physical theft of drives.
 - Example: BitLocker, Transparent Data Encryption (TDE).
2. **File-Level Encryption**
 - Encrypts specific database files or tablespaces.
 - Useful for protecting sensitive datasets without encrypting everything.
3. **Column-Level Encryption**
 - Encrypts specific columns containing sensitive data (e.g., credit card numbers, SSNs).

- Fine-grained control but higher performance overhead.
- 4. **Row-Level Encryption**
 - Encrypts individual rows, often with different keys per user or tenant.
 - Provides strong isolation in multi-tenant environments.
- 5. **Application-Level Encryption**
 - Data encrypted before being sent to the database.
 - Database stores only ciphertext; decryption happens at the application layer.
 - Strongest protection but adds complexity in key management.

Encryption Techniques

- **Weak Techniques:** Simple substitution ciphers vulnerable to statistical analysis.
- **Strong Techniques:** Depend on encryption keys, not secrecy of the algorithm.

Symmetric-Key Encryption

- Same key used for encryption and decryption.
- Example: **AES (Advanced Encryption Standard)**
 - Operates on 128-bit blocks.
 - Key sizes: 128, 192, 256 bits.
 - Successor to **DES (Data Encryption Standard)**.
- Weakness: Secure key distribution is challenging.

Public-Key (Asymmetric) Encryption

- Two keys: **Public key (E)** and **Private key (D)**.
- Public keys are published; private keys remain secret.
- Security relies on difficulty of factoring large prime numbers.
- Computationally expensive but secure.

Hybrid Approach

- Public-key encryption used to exchange a symmetric key.
- Symmetric-key encryption (e.g., AES) used for bulk data transfer.

Threats & Countermeasures

- **Dictionary Attacks:** Attackers try all possible values (e.g., dates of birth).
- **Statistical Inference:** Common values (like age 18) guessed from frequency.
- **Countermeasure:** Add random bits (salt or initialization vector) before encryption to prevent predictable patterns.

Key Takeaways

- Encryption is essential for **confidentiality, integrity, and legal compliance**.
- Symmetric and asymmetric techniques complement each other.
- AES is the modern standard; DES is outdated.
- Proper implementation (with salt/IV) is critical to resist attacks.

Encryption and Authentication

1. Password-Based Authentication

- Widely used in operating systems and databases.
- **Weakness:** Passwords sent over networks can be intercepted (“sniffed”).
- Attackers can impersonate legitimate users once they obtain credentials.

2. Challenge–Response Systems

- **Process:**
 - Database sends a challenge string.
 - User encrypts it with their password (key).
 - Database verifies by decrypting and comparing.
- **Advantage:** Passwords are never transmitted across the network.

3. Public-Key Challenge–Response

- Database encrypts challenge with user’s **public key**.
- User decrypts with **private key** and responds.
- Benefit: No need to store secret passwords in the database.

4. Smart Cards

- Private keys stored securely on embedded chips.
- Keys cannot be read directly, only used for encryption/decryption.
- Protects against key theft if a computer is compromised.

5. Digital Signatures

- **Definition:** Use private key to “sign” (encrypt) data.
- **Verification:** Anyone can check authenticity using the public key.
- **Applications:**
 - Authenticate data origin.
 - Ensure **nonrepudiation** (creator cannot deny authorship).

6. Digital Certificates

- Solve the problem of verifying public keys.
- Issued by **Certification Authorities (CAs)**.
- Contain:
 - Owner’s name.
 - Owner’s public key.
 - Signature of the issuing CA.

Verification Process

- Certificates form a **chain of trust** from root authorities down.
- Browser stores root CA public keys.
- HTTPS uses certificates to authenticate websites and establish secure sessions.

Applications in Web Security

ITEL 5 – Advanced Information Management

- Prevents malicious sites from masquerading as legitimate ones.
- HTTPS protocol:
 - Site provides certificate.
 - Browser verifies it.
 - Public/private key exchange establishes a one-time symmetric key for session encryption.
- Certificates also authenticate users in secure systems.

Key Takeaways

- Passwords alone are insecure; challenge–response improves safety.
- Public-key cryptography strengthens authentication.
- Smart cards protect private keys.
- Digital signatures ensure authenticity and nonrepudiation.
- Digital certificates establish trust in web communications.

Reference:

- Silberschatz, A., Korth, H. F., & Sudarshan, S. (2020). *Database System Concepts* (7th ed.). McGraw-Hill.